

**INTERNATIONAL CYBERSECURITY AND
DIGITAL FORENSICS ACADEMY**

**(ICDFA) GRC Engineering (CGRCE) – Level 8
(Phase 2) EXA CODE: GRC4991**

**EXAM TITLE: APPLIED GRC CASE STUDY
ANALYSIS**

Name: Shirizane Magadla

Date: 25 April 2026

SECTION A: GRC ENGINEERING & AUTOMATION

Question 1: The Evolution of Controls

a) Scenario: Transitioning to Controls-as-Code (CaC)

Question: CyberCorp, a rapidly scaling FinTech startup, is facing compliance bottlenecks due to manual security reviews in its CI/CD pipeline. As a GRC Engineer, advocate for the adoption of Controls-as-Code (CaC) and critically analyze how CaC transforms their compliance posture and operational efficiency. Justify your argument with examples.

Answer: Controls-as-Code (CaC) fundamentally shifts CyberCorp's compliance approach by embedding compliance directly into its CI/CD pipeline as automated, repeatable code. This eliminates the need for manual audits, reduces human error, and accelerates deployments.

How CaC Transforms Compliance and Efficiency:

1. Automation of Controls:

- CaC replaces manual reviews with automated scripts that continuously validate security configurations (e.g., checking IAM policies or verifying S3 bucket permissions).
- **Example:** Using Terraform or AWS Config Rules, CyberCorp can enforce "No Public Access" policies on S3 buckets automatically.

2. Scalability:

- CaC scales with the organization's infrastructure. As CyberCorp grows, new deployments inherit pre-defined compliance rules without additional manual effort.

3. Real-Time Validation:

- Security and compliance are checked during development and deployment, preventing misconfigurations from reaching production.
- **Example:** Automated checks can block deployments if they detect unencrypted databases or weak IAM roles.

4. Reduction of Human Error:

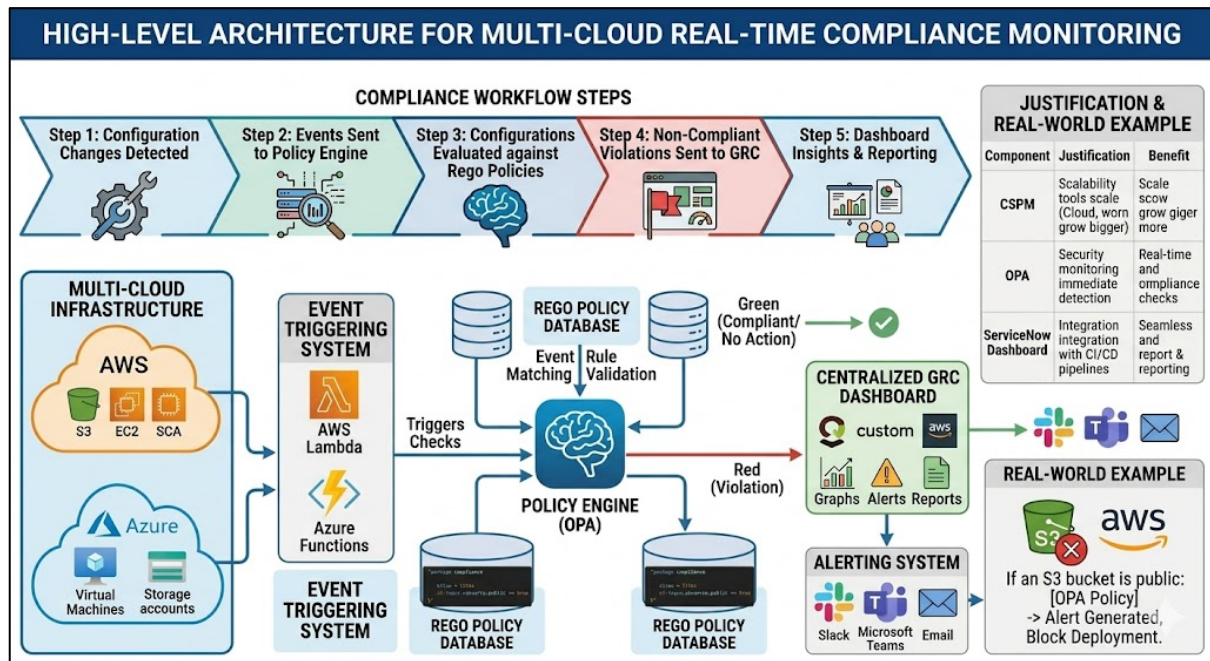
- By codifying controls, CyberCorp minimizes reliance on manual processes prone to oversight, enhancing security consistency.

Conclusion: Adopting CaC transforms CyberCorp's CI/CD pipeline into a compliance-by-design process. This approach not only accelerates delivery but also strengthens security and satisfies regulatory requirements proactively.

b) High-Level Architecture for Real-Time Compliance Monitoring

Question: Propose a high-level architecture for an automated, real-time compliance monitoring system for CyberCorp that checks for misconfigurations like "S3 Bucket Public Access" and "Unencrypted Databases" across AWS and Azure.

Answer: The proposed architecture integrates real-time monitoring tools, cloud-native services, and a centralized GRC dashboard. Below is a diagram of the architecture, followed by a detailed explanation.



Components and Justifications:

1. AWS Config Rules & Azure Policy:

- These services enforce compliance rules like ensuring S3 buckets are not publicly accessible or that databases are encrypted.
- Justification: Native cloud tools provide scalability and tight integration with their respective platforms.

2. CloudWatch & Azure Monitor:

- Real-time logging and alerting systems that monitor infrastructure changes and misconfigurations.
- Justification: Enable immediate detection of security violations.

3. Centralized GRC Dashboard:

- Aggregates alerts and compliance reports from both clouds into a unified view for CyberCorp's GRC team.
- Justification: Simplifies monitoring and decision-making across multi-cloud environments.

4. Actionable Alerts:

- Alerts are triggered for non-compliance and sent to Slack, Jira, or email for immediate remediation.
- Example:** An alert for S3 bucket misconfiguration is automatically sent to the DevOps team.

Conclusion: This architecture ensures continuous compliance monitoring, actionable insights, and seamless integration with existing CI/CD processes, enhancing CyberCorp's GRC posture.

Question 2: GRC Integration

a) Implementing Policy-as-Code (PaC) for Hybrid Cloud Compliance

Question: Explain how Policy-as-Code (PaC) can enforce governance at the infrastructure level for GlobalBank. Provide an example policy to prevent deploying virtual machines without encryption.

Answer: Policy-as-Code (PaC) uses code to define and enforce infrastructure policies, ensuring compliance is automated and consistent across hybrid environments.

Implementation for GlobalBank:

1. Use tools like Open Policy Agent (OPA) or HashiCorp Sentinel to codify security policies.
2. Policies are embedded into CI/CD pipelines to validate configurations before deployment.
3. Example: A Sentinel policy to enforce encryption on AWS EC2 instances.

Example Policy (Pseudo-Code):

```
policy "require_encryption" {
  rule enforce {
    all_instances = input.resources.aws_instance
    encrypted_volumes = all_instances.attachments[*].encrypted
    all true == encrypted_volumes
  }
}
```

Explanation of Policy:

- The policy checks if all AWS EC2 instances in the deployment have encrypted storage volumes.
- If any instance lacks encryption, the deployment is blocked.

Benefits:

- Automates compliance with financial regulations.
- Reduces manual errors and ensures consistent enforcement.

b) API-Driven GRC Platforms for Compliance Debt Reduction

Question: Define compliance debt and explain how API-driven GRC platforms can reduce it for InnovateTech.

Answer: Definition of Compliance Debt: Compliance debt refers to the accumulation of unaddressed compliance gaps due to rapid development cycles, leaving the organization vulnerable to audits and regulatory scrutiny.

How API-Driven GRC Platforms Help:

1. **Automated Evidence Collection:**
 - API integrations with tools like Jira and GitHub automatically collect audit evidence (e.g., code commits, change approvals).
2. **Streamlined Audits:**
 - Platforms like Drata or Vanta continuously monitor compliance, generating real-time audit reports.
3. **Proactive Gap Identification:**
 - APIs connect with AWS and other systems to identify misconfigurations (e.g., open security groups) before they become issues.

Example Integration:

- An API-driven platform integrates with GitHub to track changes to security policies, ensuring all changes are logged and compliant.

Conclusion: API-driven GRC platforms automate compliance tasks, enabling InnovateTech to focus on innovation while maintaining regulatory compliance.

SECTION B: APPLIED RISK GOVERNANCE

Question 3: Scenario-Based Risk Assessment

a) Quantitative Risk Assessment

Task: For the "Data Breach during Migration" risk at EcoStream, perform a Quantitative Risk Assessment to estimate the Annualized Loss Expectancy (ALE), given:

- Single Loss Expectancy (SLE) = \$500,000
- Annualized Rate of Occurrence (ARO) = 0.1.

Beyond the calculation, critically interpret the significance of this ALE value for EcoStream's GRC strategy and budget allocation. Discuss how this quantitative metric would influence a CISO's decision-making process regarding security investments.

Answer:1. Calculation of Annualized Loss Expectancy (ALE):

The formula for ALE is: $ALE = SLE \times ARO$ Given:

- **SLE** = \$500,000 (cost of a single data breach event)
- **ARO** = 0.1 (likelihood of the breach occurring annually)

$ALE = 500,000 \times 0.1 = 50,000$ **2. Interpretation of ALE:**

- The **Annualized Loss Expectancy (ALE)** for the "Data Breach during Migration" is **\$50,000**.
- This means EcoStream can expect an average annual financial loss of \$50,000 due to this risk.

3. Significance for GRC Strategy:

- **Budget Allocation:** The ALE helps EcoStream's CISO prioritize security investments. If the cost of mitigating the risk is lower than the ALE, the investment is justified from a financial perspective.
- **Risk Prioritization:** With an ALE of \$50,000, the CISO can compare this risk against others to determine which risks require immediate attention and resources.
- **Compliance:** For EcoStream, which handles sensitive PII, reducing the likelihood of breaches is also critical to maintaining GDPR and NDPA compliance, beyond financial considerations.

4. Influence on Decision-Making:

- The ALE provides a quantitative basis for justifying investments in security controls, such as encryption during migration or third-party auditing tools.
- For instance, if implementing an encryption system during migration costs \$20,000 annually and reduces the ARO to 0.01, the new ALE would be \$5,000, justifying the investment.

b) Comprehensive Risk Treatment Plan

Task: Develop a Risk Treatment Plan for EcoStream, addressing the "Data Breach during Migration" risk. For each of the four risk treatment options (Mitigate, Transfer, Avoid, Accept), propose a specific, actionable engineering control or strategy relevant to the

EcoStream scenario. Justify your selection by discussing its benefits, challenges, and trade-offs.

Answer: Risk Treatment Plan:

Risk Treatment Option	Actionable Control/Strategy	Benefits	Challenges & Trade-Offs
Mitigate	Implement end-to-end encryption for all sensitive data during migration using AES-256 encryption.	• Reduces risk of data breaches by ensuring confidentiality. • Aligns with GDPR and NDPA requirements.	• Encryption adds computational overhead, increasing migration time. • Initial implementation costs may be high.
Transfer	Purchase cyber insurance to cover potential financial losses from breaches during migration.	• Reduces financial impact of a breach. • Provides incident response support from the insurer.	• Does not eliminate the risk itself. • Premiums may increase over time if breaches occur.
Avoid	Delay migration until the multi-cloud environment's security controls (e.g., IAM policies, logging) are thoroughly reviewed and tested.	• Ensures a secure migration process. • Reduces likelihood of a breach.	• Postponing migration may delay business objectives. • Opportunity cost of delayed operations.
Accept	Acknowledge the risk and set aside a contingency fund for potential breaches during migration.	• No immediate cost or implementation effort. • Frees resources for other priorities.	• Leaves EcoStream vulnerable to breaches. • May lead to reputational damage and regulatory fines.

Risk Treatment Option	Actionable Control/Strategy	Benefits	Challenges & Trade-Offs
Recommendation:			
The Mitigate option is the most suitable due to its focus on reducing both the likelihood and impact of a breach. While it has higher initial costs, it aligns with regulatory requirements and protects sensitive PII effectively.			

c) ISO 27001:2022 Annex A Controls

Task: Identify and map three (3) specific controls from ISO 27001:2022 Annex A that are directly relevant to ensuring "Data Security and Confidentiality" for EcoStream, particularly concerning sensitive PII under the Nigeria Data Protection Act (NDPA). For each control, justify its relevance to the NDPA and describe how EcoStream would implement and monitor the control in its multi-cloud environment.

Answer: ISO 27001:2022 Annex A Controls:

Control	Relevance to NDPA	Implementation & Monitoring
A.8.3.1 – Management of removable media	The NDPA mandates that sensitive PII must be protected against unauthorized access during transfer.	• Encrypt data on removable media (e.g., storage devices used during migration). • Use AWS Key Management Service (KMS) and Azure Key Vault to manage encryption keys. • Regularly audit removable media usage logs.
A.9.2.3 – Secure access control	NDPA emphasizes restricting access to sensitive data to authorized personnel only.	• Implement role-based access control (RBAC) across AWS IAM and Azure AD. • Monitor access logs for anomalies using AWS CloudTrail and Azure Monitor. • Use Multi-Factor Authentication (MFA) to enhance security.

Control	Relevance to NDPA	Implementation & Monitoring
A.12.3.1 – Information backup	NDPA requires organizations to ensure data availability and integrity, even during incidents.	• Configure automated, encrypted backups for all customer PII in AWS S3 and Azure Blob Storage. • Test backup restoration processes regularly. • Monitor backup success/failure metrics in a centralized dashboard.

Implementation Example (A.9.2.3 - Secure Access Control):

- **How:** Use RBAC policies to ensure only authorized personnel can access sensitive data during migration. For instance:
 - Developers: Read-only access.
 - Security Team: Full access for monitoring.
- **Monitoring:** Audit logs using AWS CloudTrail and Azure Security Center to detect unauthorized access attempts.

Conclusion: These controls directly address NDPA’s requirements for data confidentiality and integrity, ensuring EcoStream achieves compliance while minimizing risk during migration.

SECTION C: CASE STUDY – THE CORPORATE AFFAIRS COMMISSION (CAC) BREACH

Question 4: Governance & Risk Analysis

a) Governance Failures and Proactive Mechanisms **Governance Failures:** The CAC breach highlights critical governance weaknesses that likely contributed to the unauthorized access. These include:

1. **Lack of Continuous Monitoring:**
 - Without real-time monitoring, suspicious activities (e.g., unauthorized access attempts) could go undetected until significant damage is done.
 - This creates a blind spot in identifying and responding to potential threats.
2. **Weak Identity Governance:**
 - Poorly managed user identities and access controls (e.g., excessive privileges, lack of role-based access) increase the risk of unauthorized access.
 - Failure to enforce principles like "Least Privilege" and "Separation of Duties" exacerbates vulnerabilities.

How These Weaknesses Create Vulnerabilities:

- **Continuous Monitoring:** Without automated monitoring tools, the CAC would be unable to detect anomalies such as brute force attacks or unauthorized data exfiltration in real time.
- **Identity Governance:** Weak access controls allow attackers to exploit privileged accounts or dormant user accounts, gaining unauthorized access to sensitive systems.

Proactive Governance Mechanisms:

1. **Implementation of a Security Information and Event Management (SIEM) System:**
 - A SIEM system (e.g., Splunk, Azure Sentinel) aggregates and analyzes logs from the registration portal, providing real-time alerts for suspicious activities.
 - **Benefit:** Enables early detection of breaches and faster incident response.
 - **Challenge:** Requires skilled personnel to configure and manage the system effectively.
2. **Role-Based Access Control (RBAC) with Periodic Reviews:**
 - Implement RBAC to ensure users only have access to the resources necessary for their roles.
 - Conduct quarterly access reviews to identify and revoke unnecessary privileges.
 - **Benefit:** Reduces the attack surface by limiting access to sensitive systems.
 - **Challenge:** Requires robust identity management tools and processes.

b) Evaluation of CAC's Decision to Restrict Access

Evaluation from Two GRC Perspectives:

1. **Business Continuity Management (BCM):**

- **Positive Impact:** Temporarily shutting down the portal prevents further data exfiltration, protecting sensitive corporate data.
- **Negative Impact:** Disrupts critical business registration services, potentially causing financial and reputational damage to the CAC and its stakeholders.

2. Risk Appetite:

- The decision reflects a **low-risk appetite**, prioritizing data security over operational continuity.
- While this approach minimizes immediate risks, it may not align with stakeholder expectations for uninterrupted service delivery.

Immediate and Long-Term Implications:

- **Immediate:** Loss of trust among businesses relying on the portal for registrations. Stakeholders may seek alternative solutions, impacting CAC's credibility.
- **Long-Term:** The breach and subsequent shutdown could lead to stricter regulatory scrutiny and increased compliance costs.

Alternative/Supplementary Action:

- **Action:** Implement a **segmented shutdown** approach.
 - Restrict access only to the compromised sections of the portal while keeping unaffected services operational.
 - Deploy a Web Application Firewall (WAF) to block malicious traffic and monitor for further attacks.
- **Justification:** Minimizes disruption while addressing the breach, balancing BCM and risk appetite considerations.

Question 5: Compliance & Regulatory Response

a) Breach Notification Outline to NDPC

Breach Notification Outline:

Header:

- **Subject:** Data Breach Notification – Corporate Affairs Commission (CAC)
- **Date:** [Insert Date]
- **To:** National Data Protection Commission (NDPC)

Content:

1. Nature of the Breach:

- Unauthorized access to the CAC registration portal, resulting in potential data exfiltration.
- Breach detected on **[Insert Date]**, involving exploitation of a vulnerability in the portal's authentication system.

2. Categories of Data Compromised:

- Corporate registration details (e.g., business names, registration numbers).
- Personally Identifiable Information (PII) of business owners (e.g., names, contact details).

3. Estimated Impact on Data Subjects:

- Approximately [Insert Number] individuals and businesses are affected.
- Potential risks include identity theft, fraud, and reputational damage.

4. Proposed Remediation Measures:

- Immediate shutdown of the portal to prevent further data loss.

- Deployment of a forensic investigation team to identify the root cause.
- Implementation of enhanced security measures, including MFA and encryption.

5. **Contact Points:**

- Gary Lee Lead GRC Officer, CAC
- Email: Gary.Lee@segment.com
- Phone: 011 340 7252

Justification for Key Sections:

- **Nature of the Breach:** Transparency demonstrates due diligence and builds trust with regulators.
- **Categories of Data Compromised:** Helps NDPC assess the severity of the breach and recommend appropriate actions.
- **Proposed Remediation Measures:** Shows proactive steps taken to mitigate risks and prevent recurrence.

Professional Tone:

- The notification uses clear, concise language to convey critical information while maintaining a professional tone, reflecting CAC's commitment to accountability.

Question 6: Engineering Remediation

a) Zero Trust Architecture (ZTA) Implementation Plan

Principles of ZTA:

1. **Never Trust, Always Verify:** Authenticate and authorize every access request based on user identity, device, and context.
2. **Least Privilege Access:** Grant users the minimum access necessary to perform their roles.

Implementation Plan:

1. **Least Privilege Access:**
 - Use RBAC to enforce granular access controls.
 - Example: Internal administrators can only access specific portal modules based on their roles.
 - **Engineering:** Configure RBAC policies in Azure AD and AWS IAM. Conduct periodic access reviews.
2. **Multi-Factor Authentication (MFA):**
 - Require MFA for all users (internal and external) accessing the portal.
 - Example: Combine password authentication with a one-time code sent via SMS or an authenticator app.
 - **Engineering:** Integrate MFA using Azure AD Conditional Access and AWS Cognito.

Challenges and Mitigation:

- **Challenge:** Legacy systems may lack compatibility with modern ZTA tools.
- **Mitigation:** Use API gateways and middleware to bridge compatibility gaps.

b) Controls-as-Code Snippet

Pseudo-Code for Access Control:

rego

package access_control

Input: User attempting access and associated CR ticket

```
input {  
  user: {  
    role: "admin",  
    id: user_id  
  },  
  cr_ticket: {  
    id: ticket_id,  
    status: ticket_status,  
    expiry: ticket_expiry  
  }  
}
```

Rule: Deny access if CR ticket is missing, invalid, or expired

```
deny_access {  
  input.user.role == "admin"  
  not valid_cr_ticket  
}
```

Rule: Validate CR ticket

```
valid_cr_ticket {  
  input.cr_ticket.status == "approved"  
  input.cr_ticket.expiry > now()  
}
```

Logging access attempts

```
log_access {  
  input.user.id  
  input.cr_ticket.id  
  result := "Access Denied"  
}
```

Justification:

- **Logic:** Ensures administrative access is tied to an approved, valid CR ticket, reducing unauthorized changes.
- **Enhancement:** Automates access governance, aligning with ZTA principles and improving CAC's GRC posture.